Contrôles de sécurité

Mise à jour du 7 novembre 2026, 23:20 (Europe/Paris). Cible : https://preprod.wagesse.fr, commit `627cb4fc0fcd014e8743db2249b1887fe71dd173`. Aucun test destructif sur les autres applications du VPS.

Site réellement servi

Contrôle	Résultat
HSTS	`strict-transport-security: max-age=31536000; includeSubDomains`
Type de contenu	`x-content-type-options: nosniff`
Cadres	`x-frame-options: DENY`
Référent et permissions	Referrer-Policy strict-origin-when-cross-origin. Caméra, micro et géolocalisation fermés.
X-Powered-By	Absent de la réponse.
Inscription administrateur	Le formulaire ne propose que Client et Camionneur. L'API refuse tout autre rôle.
Administration	HTTP 401 sans jeton, avec un client et avec un transporteur. HTTP 200 avec l'administrateur de recette.
PayDunya	Le mode servi est MANUAL. Le cycle n'a pas appelé de paiement réel.
JWT	Signature et vérification limitées à HS256. L'erreur de jeton n'est pas écrite dans le journal.

Vulnérabilités npm restantes

`npm audit --omit=dev` le 7 novembre 2026 sur ce lockfile : 1 critique, 8 élevées, 1 modérée. Aucun paquet n'a été monté après la recette réussie.

Paquet	Niveau	Décision
next 16.2.12	Critique	Exécution de code non authentifiée sur un serveur Windows. L'hôte est Ubuntu. La correction indiquée est Next 16.4.5, non essayée sur cette préproduction. Reportée.
prisma, @prisma/config, deepmerge-ts	Élevé	L'avis couvre Prisma jusqu'à 7.10.0. Le code ne fusionne pas des objets fournis par le client. Pas de montée majeure.
jsonwebtoken 8.5.1	Élevé	La seule cible est la version 9. L'application impose HS256. Reporté.
nanoid, postcss, sharp/libvips, source-map-js	Élevé	Chemins non utilisés : pas de générateur nanoid de taille nulle, pas de feuille de style fournie par un visiteur, pas d'appel direct à libvips hors du traitement d'images de Next.
uuid	Modéré	L'avis concerne un tampon fourni par l'appelant. Le code ne le fait pas. La cible est une version majeure.

Vérification téléphonique de production

Le numéro est vérifié par un code à six chiffres, valable dix minutes, envoyé par SMS. Cinq essais faux verrouillent le code. Un renvoi attend soixante secondes, avec au plus cinq envois par heure. La réponse HTTP ne contient le code que si `OTP_DEBUG_RETURN` vaut true et que `NODE_ENV` n'est pas production. Sur le VPS, `NODE_ENV` est déjà production : le code n'est donc pas renvoyé. Le drapeau ne doit malgré tout pas être posé.

En production, le fournisseur est HTTP. `SMS_PROVIDER=http`, `SMS_HTTP_URL` et `SMS_HTTP_KEY` viennent d'un fichier root 600, hors dépôt. `SMS_ALLOW_SIMULATE` reste absent. Sans URL ni clé, aucun SMS n'est délivré et les opérations payantes restent fermées. Le message envoyé est « WAGESSE : code de vérification … Il expire dans 10 minutes. » L'appel réussit seulement si le prestataire répond correctement. `phoneVerified` n'est écrit qu'après un code accepté.

Le code est conservé dans la mémoire du processus. Un redémarrage invalide les codes en attente. C'est acceptable pour une seule instance systemd. Le passage à un stockage partagé est reportable si une seconde instance est ajoutée.

Désactivation du mécanisme de recette

La route `POST /api/admin/recette/verify-phone` répond 404 sauf si les quatre conditions sont réunies :

1. `WAGESSE_DEPLOYMENT` vaut exactement `preprod`.
2. `PREPROD_TEST_PHONE_VERIFY` vaut exactement `true`.
3. Le nom de base dans `DATABASE_URL` est exactement `wagesse_preprod`.
4. L'en-tête Host est `preprod.wagesse.fr`, `127.0.0.1` ou `localhost`.

Le compte doit en plus être fictif : numéro `7800` suivi de quatre chiffres, nom contenant « Recette », rôle ni ADMIN ni SUPER_ADMIN. La réponse ne contient pas de code. `NODE_ENV=production` ne suffit pas à ouvrir la route, parce que la préproduction tourne déjà dans ce mode.

Les trois premières conditions sont dans le commit déployé. Le contrôle d'hôte est ajouté dans le dépôt après cette recette. Il n'est pas encore redémarré sur le serveur. Un fichier d'environnement copié vers un site `wagesse.fr` échoue déjà si le nom de déploiement ou la base change. Le script `deploy/production/assert-env.mjs` refuse, sans imprimer les secrets, un fichier qui contient le déploiement preprod, le drapeau fictif, la base de préproduction, le retour de code, la simulation SMS, ou l'absence d'URL et de clé HTTP.